



# Folios Deep Audit — 2026-06-17

FOLIOS · FOLIOSHQ.COM

---

Status: IN PROGRESS. Read-only audit (safe one-liners auto-fixed inline, tagged ↗).  
Durable record — env resets between turns; this file is the source of truth.

## Method

- 14 domains (D1-D14), every file assigned.
- 10 lenses per domain: Correctness · Security (RLS/JWT/injection) · Data integrity · Pip quality (parity+data-line) · Performance · Coherence (Frankenstein) · Theme (dark+light) · Mobile/a11y · Docs/config drift · Test coverage.
- 6 output tags: 🔧 Fix · 🕒 Gap · 📊 Opportunity · ✨ New feature · 🧠 Pip evolution (Feed/Form) · ↗ Auto-fixed.
- Cross-cutting sweeps: Pip context parity · Data-line · Coherence · Live DB advisors · Guard/CI · **Pip Architecture Review**.

---

## Finding format

```
[Dn][lens][tag][sev: P0/P1/P2/P3] file:line — description → recommendation
```

---

## — EXECUTIVE SUMMARY —

**Scope:** all ~230 files (14 domains) + live Supabase DB + config/CI/deps/static. Read-only audit. ~140 findings.

**Overall verdict:** Folios is in **fundamentally sound shape** — the scary classes are clean. The Pip API passed every locked rule (Anthropic-in-try-catch, JWT/RLS, usage logging, data-line). The DB RLS posture is solid (item 47's work held — zero RLS-initplan/FK lints on Folios tables). Hook Order + Service Worker + Fonts all pass. The cost architecture is structurally good. **No P0 data-loss or auth-bypass bugs in the live app.** What's left is a mix of contained bugs, a strong architectural opportunity for Pip, and a long tail of coherence/a11y/theme polish.

### The 5 meta-findings (the patterns that matter more than any single bug)

1. **"Built but never wired" is the dominant bug class.** Capabilities exist in some Pip paths but are silently missing in others (globalPeople, health/promise/waiting-on memory, operator state, owner-suppression, is\_commitment, discussedProjectIds). Much of "Pip feels dumb" is **plumbing, not the model.** → X6 root-causes this to 3 drifting context renderers; one `buildAccountContext()` layer fixes the whole class.
2. **The dual task-model split-brain in Gauge** — tasks live in both `gauge_projects.stages` and `folio_tasks` ; no single queue view shows both. Real, ongoing.
3. **owner\_user\_id "isMine" suppression is half-applied** — the MSO/not-mine accounts you silenced still reappear in Home's Fires/Ahead cards, generate-questions, StatusBanner. Needs one shared helper.
4. **CI guard holes** — Guard 1 can't see *missing* catches or comment-only bodies; CI runs no lint and no npm audit. The safety net has gaps.
5. **The standalone `/gauge/` directory is dead + dangerous** — abandoned pre-V3 app, not deployed, carrying 2 P0 security violations + Google-Fonts CDN. Biggest one-move security-surface reduction: delete it.

### Must-fix list (P0/P1 — ranked)

- **P0** `Pill.jsx:5` — `var(--c-text-mute)` typo (token is `--c-text-muted`) → every `<Pill>` without explicit color = **invisible text app-wide**. One char. ↵
- **P0** `leadership-readout.js` + `portfolio-brief.js` — large code blocks run OUTSIDE try-catch → `FUNCTION_INVOCATION_FAILED` on the boss

readout + daily brief.

- **P1** `ask-pip.js` — missing `maxDuration:60` → "Ask Pip on a meeting" silently times out at Vercel's 10s default.
- **P1** `cadenceUtils.js:65` — biweekly cadence with null anchor → NaN dates (corrupts reminders/calendar/Pip).
- **P1** `StandingBoardView.jsx:48` — completing the last kanban card doesn't mark the project complete.
- **P1** `useItems.js:38` — ItemsTab "Closed" section permanently empty (completed tasks vanish).
- **P1** `api/invite.js` — `appUrl` from request body unvalidated (phishing-link vector) + no rate limit.
- **P1** `useAuth.js` — `folio_portfolio_brief_` not wiped on signout → Pip's portfolio analysis readable by next user on shared device.
- **P1** `schema.sql` — canonical file has the WEAK `members_self_accept` policy (phase1\_security.sql hardening never folded in) → fresh-rebuild role-escalation gap.
- **P1** Chat-Pip blind to `globalPeople/health/promise` (the #1 "doesn't recognize known people" complaint) — renderer supports it, caller doesn't populate it.
- **P1** `CommitmentsView.jsx:95` — account tap passes wrong arg type → opens wrong account/crashes.
- **P1** Gauge dual task-model split-brain (meta-finding #2).
- **P1** check-guards Guard 1 missing-catch blind spot (meta-finding #4).

### Pip — the three lanes you asked for (full detail in X6)

- 🧠 **FEED:** wire chat to its own renderer's fields (`globalPeople/health/promise`) [`#1`]; `operator-state`→`summarize`; `pre-meeting check-in answers`→`summarize`; `waiting_on`→`cadence brief + leader rollout`.
- 🏗️ **FORM (sequence):** cache fixes (free money) → `buildAccountContext()` **single layer [THE ONE THING]** → event-driven recompute (70-90% cost cut) → persist structured context → real agent loop (`tool_result` round-trip) → pgvector semantic recall.

- ✨ **NEW:** digest as a *reasoning* ingest (closes the capture gap), admin instruction-writer, event-driven proactive Pip, true conversational memory ("what did we decide about All Star in spring?").

### Biggest NEW-FEATURE / OPPORTUNITY highlights (beyond fixes)

- Semantic recall over all notes/summaries (the real "portable brain") — X6 F6.
- Real agent loop so Pip acts→observes→continues instead of one-shot — X6 F5.
- Team request-queue → Excel export (Game Plan Phase 2.2) gets easier once context is materialized.
- Delete `/gauge/` (security) + consolidate SettingsView/CadenceHub/HomeView/pip.js (all >1500 lines) into sub-modules.

### Decisions needing your call before the fix phase

1. **Delete `/gauge/` ?** (recommended KILL — dead + 2 P0 security violations). High-impact deletion, want your yes.
2. **`home-hub.html`** public mockup has real account names — delete or fictionalize?
3. Auto-fixes: I'll apply the safe < one-liners (below). Everything P1+ waits for your fix-phase greenlight.

---

### ⚡ AUTO-FIXES APPLIED (safe one-liners, local working tree only — NOT pushed)

1. ✓ `src/components/Pill.jsx:5` — `var(--c-text-mute)` → `var(--c-text-muted)` (P0 dead-token; verified --c-text-mute defined nowhere, --c-text-muted in all 3 palettes).
2. ✓ `src/components/QuickActionBar.jsx:82` — `inputStyle fontSize 13` → `16` (fixes input AND select via spread; Mobile Input Rule).

3. ☒ `src/hooks/useFolioHealth.js:89` — canary label "Overnight operator run" → "Pip's operator pass" (operator is manual-trigger now).
  4. ☒ `src/components/Pip0rb3D.jsx:3` — stale "2.4s cycle" comment → "4.8s cycle". Everything P1+ and all multi-line/judgment fixes await the fix-phase greenlight.
- 

## Domain status tracker

- ☒ D1 App shell & routing
- ☐ D2 Auth · org · session · activity
- ☒ D3 Accounts core
- ☒ D4 Account tabs & contacts/items
- ☒ D5 Cadence & meetings
- ☒ D6 Summarize pipeline
- ☒ D7 Gauge
- ☒ D8 Home · operator · check-in · commitments
- ☒ D9 Pip brain — context/logic (client)
- ☒ D10 Pip API endpoints (server)
- ☐ D11 Pip + Hex visual system
- ☐ D12 Shared components & design system
- ☐ D13 Life · capture · reliability · DB · static/public · config · CI · deps
- ☒ D2 Auth · org · session · activity
- ☒ D11 Pip + Hex visual system
- ☒ D12 Shared components & design system
- ☒ D13 Life · capture · reliability · DB · static/public · config · CI · deps
- ☒ D14 Standalone gauge/ app (keep/kill verdict)
- ☒ X1 Pip context parity sweep
- ☒ X2 Data-line compliance sweep
- ☒ X3 Coherence sweep
- ☒ X4 Live DB advisors (MCP)

- ☒ X5 Guard/CI integrity
  - ☒ X6 Pip Architecture Review (Opus)
- 
- 

## Findings

---

### D6 — Summarize pipeline ☒

Some items carry "verify" hedges (agent couldn't confirm cross-file) — re-check before auto-fixing.

#### Top 5 (highest impact):

1. [P0] AdHocConversationFlow.jsx:164-173 — `discussedProjectIds / discussedItemIds` not forwarded into `previewPlan` state → every ad-hoc summarize throws away Pip's project-routing signal.  FIX
2. [P1] pipPlanApply.js:118-130 — `new_task` Gauge-staging path drops `is_commitment` → commitment-flagged tasks routed to a project never reach "Your word"/nudges/ledger.  FIX
3. [P1] pip.js:1238-1248 — `normalizePlanRow` `new_task` branch drops `suggested_project_title` → "Pip suggests a project" banner never fires for task rows.  FIX
4. [P1] DigestIngestModal.jsx:91 — OWE rows call `insertTask({title:...})` but column is `text` → possible silent null-text task creation (verify useTasks.insertTask shape).  FIX
5. [P1] AdHocConversationFlow.jsx:110-155 — ad-hoc summarize omits `healthSnapshots / promiseStats / cadence` that CadenceHub passes → parity gap, worse plans on higher-stakes reactive meetings. 🧠 PIP-FEED

**Correctness:** pipPlanApply flushStages full-overwrite race (P2, no atomic RPC for stages); update\_task silent no-op when findIndex=-1 (P2, add warn/correction log); UTC "today" in renderCommitmentsInBlock (P2 ↗, use ET-anchored date). **Security:** SUMMARIZE\_SCHEMA\_RULES lacks injection-resistance line for untrusted meeting notes (P2 ➡); verify addMeeting/insertTask in DigestIngestModal use JWT-scoped client (P1); WORK\_CLAUDE\_PROMPT ships in client bundle (P3, note only). **Data integrity:** AdHocConversationFlow handleApplyPlan passes `cadenceId:` `adHocCadenceId` (undefined?) — set explicit `null` (P1); digestParse.js:107 "Thread with null went quiet" guard (P2 ↗); TOUCH-row meetings get null pip\_summary → history expansion shows empty Pip field (P2); confirm close\_item sets closed\_at (P2). **Pip quality / feed:** waiting\_on/waiting\_on\_since not in SUMMARIZE\_SCHEMA\_RULES (P2 🧠 FEED); no meeting-type branch (1:1 → prefer cadence-task) in schema rules (P2 🧠 FORM); verify project\_notes provenance labels use project TITLE not UUID (P2 🧠 FEED). **Performance:** projectSuggestions useMemo busted by inline onCreateProject in all 3 callers — useCallback (P2 📉); plan-sanitize memo reruns on array-identity churn (P3); StartConversationModal useContacts fires with null accountId on open (P3). **Coherence:** METHOD\_LABEL duplicated in AdHocConversationFlow + StartConversationModal → extract shared (P1 🔧); verify AccountDetail summarize forwards `receipts` (P2); follow\_up\_date written but not editable in preview (P2 ➡). **Theme:** verify light-mode defs for --c-accent-glow/--c-accent-line (SummarizeStreamingOverlay) + C.yellowFaint (DigestIngestModal) (P2-3). **Mobile/a11y:** PersonPicker fontSize:12 wrapper in preview risks iOS zoom (P2 🔧); SummarizeStreamingOverlay has no role=dialog/aria/ESC/reduced-motion + no error/hang recovery → user can get stuck behind overlay (P2 ➡, two findings). **Docs:** document client-side WORK\_CLAUDE\_PROMPT in ai-governance.md (P2); document `===PLAN===` two-phase delimiter as locked interface (P3). **Tests:** pipPlanApply.js ZERO coverage — highest-consequence write fn (P1 ➡); normalizePlanRow edge cases untested (P1); digestParse QUIET-without-person case (P2); overlay error path (P3).

---

## D9 — Pip brain / client context

DOMINANT THEME: chat (Ask Pip) is the parity loser — it sees far less than summarize. This recurs across findings.

### Top 5 (highest impact):

1. [CRITICAL] `PipView.jsx` `buildContext()` + `pipContext.js` — **global People Directory absent from chat.** `globalPeople` is assembled in `App.jsx` & passed to `PipView` but never used; `renderPeopleDirectoryBlock` only runs in `summarize`. → Chat Pip can't tell known people from new → directly your #1 failure mode (suggests already-known people as new contacts). Wire `globalPeople` → `buildContext` → `renderContextProse`. 🛠️ FIX/🧠 FEED
2. [HIGH] `PipView.jsx:241-243` + `pipContext.js:406-468` — **dead memory in chat:** `healthSnapshots`, `promiseStats`, and `project` `waiting_on/waiting_on_since/assignee/requested_by` are rendered by `pipContext` but never populated by `buildContext` → `who-has-ball` + `health trend` + `delivery record` invisible to chat. 🛠️ FIX
3. [HIGH] `pip.js:724+` `summarizeDraftPip` — **operator state absent from summarize.** Pip summarizing a meeting has no awareness of operator-loop situation/risks/draft for that account → can re-suggest already-flagged work. Pass `operatorState` into `bp3Text`. 🧠 FEED
4. [HIGH] `pip.js:529-601` `callBriefMePip` — **Brief Me (a workhorse) missing healthSnapshots + recentUpdates + project waiting\_on/assignee.** Pre-call brief lacks `health momentum` + `account-updates calendar` + `who-owns/blocks`. 🛠️ FIX/🧠 FEED
5. [MEDIUM] Unbounded queries: `usePipAccountState.js:29`, `usePipAssignmentHints.js:26`, `usePipFacts.js:24` — no `.limit()` ; loaded at cold-open + refetched on realtime. Add caps (50/200/50). 📊/⚡

**Correctness/parity (more):** `SCHEDULE_RE` in `pipIntent.js` could answer deterministically from context but falls through to LLM (P3, cost 🧠 FORM); `detectKnowledgeGaps` `contact-count` keyed by `c.name` not canonical → threshold questions never fire on nickname mismatch (P2); `pipTools` `update_account_health` `enum ["active",at_risk,cold]` vs DB `healthy/watching/at_risk` — verify `routeToolCall` translation (P2). **Security/data-line:** `remember_fact` tool description doesn't forbid quantitative business data → Pip could store a number from chat (P2 🧠 FORM); `compressCorrectionsPip` prompt lacks data-line generalization → corrections mentioning \$ could embed in `lessons_learned` (P2). **Performance:** `portfolioThemes` `Object.assign`'d onto EVERY account → same blob serialized Nx in payload; make top-level (P2 📊/cost); `cachedStateMap` re-iterated each render, use `Memo` (P3). **Coherence:** three Pip surfaces (`chat/Brief Me/summarize`) have three different context-richness levels — root of inconsistent answer quality (HIGH); project



representation differs (summarize has stages, others don't); EVERGREEN\_QUESTIONS still exported though deprecated — rename (P3). **Theme:** PipCatchUp textarea uses C.bgDark → may be invisible in light mode, use input token (P2); verify C.accentGlow light-mode def. **A11y:** PipCatchUp Skip/lock-in/textarea lack contextual aria-labels (P3 ×3). **Tests:** pipIntent.js no tests (rules engine gating LLM-call cost — MEDIUM); detectKnowledgeGaps, usePipDripQuestions throttle window, pipTools routing all untested.

---

## D3 — Accounts core

NB: this agent also surfaced findings in api/pip-state-refresh.js & api/generate-questions.js (overlap w/ D10 — cross-confirmed).

### Top 5 (highest impact):

1. [P1] folio\_merge\_accounts — **does not re-parent**  
`folio_pip_questions.suggestion.account_id` → post-merge drip  
"Also save to..." writes to dead/inactive account = silent data loss on a user action. One SQL jsonb\_set fix. 🐞GAP. (Also misses folio\_contact\_aliases.account\_id — P2.)
2. [P1] accountHealth.js:98 computeMissedCadences — bare `meeting_date` parsed as UTC → off-by-one after ~8pm ET → spurious "cadence missed" signals. Fix `+'T00:00:00'` (pattern already at L11). 🔧 FIX
3. [P2] api/generate-questions.js — no `owner_user_id` in select → drip questions generated for not-mine (MSO) accounts; item 38 suppression never applied here → erodes Pip credibility on most-visible surface. 🔧 FIX
4. [P2] api/pip-state-refresh.js:208-209 — no  
`account_type / is_my_department / owner_user_id / systems` selected → internal departments get external "churn risk / long\_silence" state framing; also misses multi-account projects (account\_ids not OR-queried, unlike operator-run). 🔧 FIX/🧠 FEED
5. [P1] **Health pill contradicts sparkline** — AccountDetail header + AccountsView call gatherSignals WITHOUT cadences/meetings → missedCadences always 0; OverviewTab sparkline reads snapshot health (which

includes cadences) → header says "Healthy" while sparkline shows "watching".  
Pass cadences+meetings into gatherSignals on detail view. ✨/🔧

**Correctness:** AccountDetail.jsx:228 todayISO uses UTC not ET (P2 ↗, use etToday from accountSnapshots). **Security:** folio\_merge\_accounts correctly uses security invoker (confirmed good); pip-state-refresh writes relationship state for not-mine accounts (behavioral, ties to #3/#4). **Data integrity:** merge deletes source pip\_account\_state but never refreshes target → stale state card post-merge; touchAccount(target) or toast (P2). **Coherence:** STATUS\_LABELS duplicated in AccountDetailHeader:25 + AccountsView:34 → export from accountHealth.js (P2 ↗); dual health vocab green/yellow/red (runtime) vs healthy/watching/at\_risk (snapshot) used on same concept across files — document/unify via exported map. **Theme (hardcoded rgba, light-mode breakage):** AccountDetailHeader.jsx:225 Cooling pill rgba(251,191,36) (P2 🔧); AccountsView.jsx:1248 tag filter rgba(91,143,212) (P2 🔧); AddAccountModal:34,577 raw purple (P3); ProjectsTab.jsx:171 rgba(255,255,255,0.06) border invisible in light (P3 ↗). **Mobile/a11y:** AccountDetailTabs lacks role=tablist/tab/aria-selected (P2 🔧); AccountMergeModal "ARE YOU SURE" div needs role=alert (P2 ↗); Mine/Not-mine toggle needs aria-pressed (P3). **Docs:** operator "nightly cron" stale (known); merge re-parenting extensions not in data-handling.md (P2). **Tests:** computeMissedCadences not exported/tested (date-boundary bug would need post-8pm run to catch) (P2); touchAccount no tests despite hot path (P2); accountExport + merge RPC untested (P3).

---

## D10 — Pip API / server / cost

PASSES confirmed: Anthropic-in-try-catch (all 12), JWT/RLS (all .from paths), logPipUsage (all 11), data-line instructions (all generative endpoints), model tiering correct, operator-run shared-context caching = excellent.

### Top 5 (highest impact):

1. [P0] **leadership-readout.js:32-79 + portfolio-brief.js:47-293 run OUTSIDE try-catch** → any throw = Vercel raw crash page, not JSON; error boundary swallows it, folio\_errors gets nothing. Breaks boss-facing readout + daily brief silently. Extend outer try-catch. 🔧 FIX
2. [P1] **ask-pip.js missing maxDuration:60** → defaults to 10s; meeting-mode Haiku runs 12-20s → killed before client's 70s timeout → "Ask Pip on

meeting" silently network-errors. One-line.  FIX

3. [P1] **5 endpoints send static system prompts with NO cache\_control** (business-review, detect-terminology, generate-questions, leadership-readout, profile-synthesis). generate-questions (Sonnet) alone: ~60-70% per-call cut. Add cache\_control once blocks  $\geq 1024$  tok.  GAP/cost
4. [P1] **pip-state-refresh.js:293 Promise.all up to 50 simultaneous Haiku calls** (no wave throttle, unlike operator-run's 4)  $\rightarrow$  morning chat-open+periodic triggers fire  $\sim 20$  parallel  $\rightarrow 429$ s  $\rightarrow$  state silently goes stale. Add ACCOUNT\_CONCURRENCY=4 waves; long-term Batches API (50% off, already TODO'd).  FIX/cost
5. [P2] **stop\_reason unchecked** in ask-pip account/brief modes + pip-state-refresh  $\rightarrow$  truncated Haiku writes partial/corrupt data silently (state-refresh clobbers VALID state with partial). Add max\_tokens guard + skip-and-log.  GAP

**More:** ask-pip account/brief truncation (P1, see #5); pip.js streaming+buffered should emit `truncated:true` in meta (P2); detect-terminology + followup-question lack server rate limits (P2 defense-in-depth); followup-question answerText uncapped  $\rightarrow$  cap 4000 (P2). **Cost (  PIP-FORM / cost):** \_pipUsage.js:122 hardcoded `-05:00` offset  $\rightarrow$  spend-cap "today" boundary off 1h during EDT (P3  $\nearrow$ , use Intl ET);

**summarizeDraftPip BP2 cache fragility** — profileProse varies by 1 char (whitespace/re-synthesis)  $\rightarrow$  4-block cache collapses,  $>2\times$  input cost silently (P2-P3  FORM, normalize+freeze profileProse per session); operator-run draft\_email on-demand confirm empty when not triggered (P2, item 48); Batches API for pip-state-refresh (P2, 50% off when volume grows). **Model/prompt:** ask-pip.js:38 may still carry "Be GENEROUS" aggressive-extraction language bleeding into meeting mode  $\rightarrow$  replace w/ precision doctrine (P2 — verify; contradicts item 47 B4 claim). **Client libs PASS:** pip.js (fetchWithAuthRetry, 4-block cache = best in codebase), net.js, usePipUsage, useKokoroTTS (iOS 15s race), usePipTTS — all clean.

**COST VERDICT:** architecture structurally sound (caching on 3 highest-freq surfaces, good tiering, operator-run shared-context cache eliminates worst rebilling). Remaining leverage = 1-3 line changes, multiplicative payoff: (1) cache 5 uncached static blocks; (2) throttle pip-state-refresh burst + Batches API; (3) activity-gate pip-state-refresh triggers (item 48.3 — cuts 70-90%); (4) fix BP2 cache fragility. No architectural rethink needed.

## WAVE 1 CROSS-DOMAIN PATTERNS (emergent)

- **"Built but not wired" is the dominant bug class.** globalPeople, health/promise/waiting-on memory (chat), operator state (summarize), owner\_user\_id suppression (generate-questions/pip-state-refresh), account\_type/is\_my\_department awareness (pip-state-refresh), is\_commitment (Gauge staging), suggested\_project\_title (new\_task), discussedProjectIds (ad-hoc) — all EXIST somewhere but silently missing elsewhere. Much of Pip's perceived dumbness = wiring, not model. → A single "Pip context assembly" consolidation (one materialized context layer feeding all surfaces) would kill this whole class — candidate 🛠️ Pip-Form headline.
- **Chat < Brief Me < Summarize** in context richness — three tiers of the same data → inconsistent answer quality. Parity rule is violated structurally, not per-field.
- **UTC-vs-ET date parsing** recurs (accountHealth:98, AccountDetail:228, pip.js commitments block, \_pipUsage:122) despite dateUtils existing — guard 2 only catches toLocaleDateString, not `new Date("YYYY-MM-DD")` . → Extend a guard.
- **Hardcoded rgba light-mode breakage** recurs (D3 found 4) — likely systemic; X3 coherence sweep should quantify.

---

## D1 — App shell & routing

PASSES: **Hook Order Rule clean** (all hooks traced above authLoading guard at App.jsx:883, marker present); **SW dual-update paths intact** (main.jsx controllerchange + version polling + chunk-reload + reloading guard; vite.config navigateFallbackDenylist + skipWaiting/clientsClaim/cleanupOutdatedCaches).

### Top 5 (highest impact):

1. [P2] App.jsx:875-879 — **share-target detects on ANY URL with ? title/text/url** , not just `/share-target` → a normal link with those params hijacks app into ShareTargetView. Add `pathname === "/share-target"` check. 🛠️ ↩

2. [P2] App.jsx:183 — `fetchAllUpdates` (folio\_account\_updates) fires every cold open but ONLY consumed by PipView → gate to view==="pip". 
3. [P2] App.jsx:870 useRecentThemes — 90-day meetings×accounts JOIN fires every cold open regardless of view → gate to Home. 
4. [P2] docs/ suite still documents operator as nightly cron (retired June 17, production-live) → docs lie about how it works = compliance/trust risk. 
5. [P2] No CI guard for hook-order (React #310 bit Chris 3×) → add Guard 5 to check-guards.js: grep use(State|Effect|Memo|Ref) below authLoading return. / 

**Cold-open query budget: ~18-20 concurrent** (Batch 6 target was 15). Gating

wins: useCustomWorkspaces→Accounts nav (often empty), useOrg ×2 always fires for solo user (cache solo flag), useRecentThemes→Home, fetchAllUpdates→Pip. 

**Correctness:** App.jsx:1458 ScheduleMeetingModal passes redundant user\_id override (inconsistent w/ other addMeeting calls) — verify useMeetings injects internally (P2); handleSetView 200ms nav timer race on double-tap → "Select an account" flash (P3).

**Security:** App.jsx:1434 onAddContacts inline supabase.insert with no .catch — only direct DB write in render body, silently swallowed (P3 ✗, route through hook).

**Coherence:** handlers bags rebuilt every render (HomeView:1175, AccountDetail:1110) — new object identity blocks React bailout; memoizing needs hooks above

authLoading (deferred per Batch 8, architectural debt note). **Theme:** index.html Life dark `[data-mode="life"]` doesn't redefine `--c-tier/--c-status/--c-glass-*` → green halos on blue if Gauge ever renders in Life (P2 latent → Life Phase 2 token audit); light+life inherits white glass (P3); DesktopLayout:171 gauge nav bg hardcoded `rgba(91,143,212)` (P3 ✗). **Mobile/a11y:** MobileLayout workspaces popover lacks id/aria-controls link (P2 ✗); no skip-to-content link on mobile (desktop has one) + main scroll div has no id (P3); Pip nav only tab with no visible text label (minor). **Tests:** no automated hook-order / share-target / mode-bootstrap coverage (P2 — Guard 5 candidate).

---

D4 — Account tabs / contacts / items  (THE FRANKENSTEIN EPICENTER — confirmed)

Heavily coherence-dominated: tabs diverge on identical data + bypass shared hooks/components.

## Top 5 (highest impact):

1. [P1] useItems.js:38 `.eq("done", false)` → **ItemsTab "Closed" section permanently empty** — completed tasks vanish, no way to review what was done on an account. Parameterize done filter / 2nd query on expand. 🛠️ FIX
2. [P1] ItemsTab.jsx:255 — `recipient.split("@")[0]` **email local-part leak** (class fixed elsewhere, missed here) → ownerLabel(). 🛠️ ↗
3. [P1] CadenceTab.jsx:291,294 — pip\_summary rendered as plain `<em>` (loses markdown) while MeetingsTab uses MarkdownText; AND delete fires with NO confirm (MeetingsTab has two-step) → mis-tap destroys meeting. Two single-component subs. 🛠️ FIX
4. [P2] contactEngagement.js:68 — reads nonexistent `m.date`, falls back to created\_at not meeting\_date → **"last seen Xd" silently wrong**; poisons staleness detection + chips. 🛠️/🧠 FEED
5. [P2] MeetingsTab.jsx:121-135 sendToGauge — direct supabase.insert bypasses addProject → no account\_ids[] (project invisible on linked accounts), no logActivity, no realtime. 🛠️ FIX

**Coherence (more):** OverviewTab:793 sub-account label "Watch" not "Watching" (Batch 5 missed, P2 ↗); ContactsTab:277 builds insight without PipInsightCard wrapper (loses hex/collapse, P2); 4 tabs use bespoke empty-state divs not shared EmptyState (ShopsTab/UpdatesTab/ProjectsTab/CadenceTab, P2); ProjectsTab:122-132 + :241 completion task inserts via raw supabase, ProjectModal missing userId/members → no touchAccount/logActivity/source/pip\_created\_at (P2); AddItemModal title "Add Open Item" vs tab "Open Items" vs "Edit Task" naming mismatch (P3 ↗); MeetingsTab:137 copySummary reads legacy action\_items/commitments blobs (empty post-unification, P3). **Add/edit parity:** EditContactModal has is\_primary toggle, AddContactModal doesn't → can only set primary by editing (P2). **Theme (light-mode breakage):** MeetingsTab:387 rgba(0,0,0,0.2) dark smear on light (P2); MeetingsTab:339 →Gauge btn hardcoded blue → use statusPlanned token (P2); OverviewTab:620 cold-contact alert rgba(204,140,0) (P2); AddContactModal:127 rgba(74,155,130,0.07)→C.accentFaint (P3 ↗). **Realtime/hooks:** OverviewTab:90 direct gauge\_projects fetch in useEffect, no hook/realtime/.limit (P2); useContactAliases:15 silent success/fail no logSilentFailure + no realtime (P3); useAccountNotes no realtime (P3 OPP). 🧠 **PIP-FEED gaps:** relationship\_note (why champion/blocker) never rendered in Overview NOR fed to pipContext renderContactsBlock (P2); ContactsTab CSV omits is\_leader/relationship\_role/relationship\_note (P2); PrintAccountSheet omits

leader/role (P3); EditMeetingModal talking\_points/action\_items/commitments are orphaned legacy blobs invisible to Pip → hide behind "legacy" disclosure (P3). **A11y:** AddContactModal/EditContactModal toggle divs lack role/tabIndex/onKeyDown (P3 ↗); verify CadenceTab inline add-contact ≥16px (Batch 7 may have missed this distinct surface vs CadenceMeetingMode) (P2). 🧠 **PIP-FORM:** OverviewTab:679 "Recent Deliveries" filters by "✓ Delivered:" string prefix — fragile, use source flag (P3).

---

## D5 — Cadence & meetings

Note: the two CalendarView files (cadence/ vs calendar/) are INTENTIONAL (cadence one is scoped to CadenceView) — not dead code, but undocumented. Several "verify at build" hedges on Batch 2/7 items.

### Top 5 (highest impact):

1. [P0] cadenceUtils.js:65-83 — **biweekly cadence with null anchor\_date AND created\_at → new Date(undefined) → NaN**, silently wrong dates for all biweekly recurrence → corrupts reminders/calendar/Pip cadence feed. Guard + fallback. 🔧 FIX
2. [P1] useMeetings.js:19 — per-account fetch has NO `.limit()` (global has 300) + selects `*` incl. notes/pip\_summary/pip\_email blobs → largest payload in app, slow cadence-hub on mobile. Column-select + limit(150). 🔧 FIX/perf
3. [P1] CadenceHub BeforeYouStart — **pre-meeting check-in answers ("something changed — they left MSO program") never fed into summarize** → context-correction value lost; pass as PRE\_MEETING\_NOTE. 🧠 PIP-FEED
4. [P1] CadenceHub:1338-1347 — multi-dept roster merge has **no dedup** → contact in 2 depts appears twice in Pip payload → double-weights / "add known person". Dedup by id. 🔧 FIX/🧠 FEED
5. [P1] **Circular import** CadenceMeetingMode.jsx:7 ↔ CadenceHub.jsx:11 (HubProjectCard/PipBriefPanel/OpenItemRow) → fragile; any code-split creates hard cycle. Extract 3 shared comps. 🔧 FIX/🧠

**Correctness:** CalendarView gauge due-date extraction non-deterministic when 2 "due" custom fields (P1, prefer exact "Due Date"); weekly getNextOccurrence returns today even if meeting already passed → spurious banner flash (P2);



useCadenceReminders DST 1h shift twice/yr (P2 doc-only); CadenceHub:2314 clipboard .then no .catch → Guard 1 violation, silent copy fail (P2 ✗). **Performance:** useMeetings global selects \* (3 blobs × 300) = biggest cold-open fetch → column-select (P1); CadenceHub 2416 lines re-evals on any state (P1, verify useProjects/useItems callbacks stable); useCadences/usePersonCadences no .limit + inner fetch not useCallback → re-fetch loop pattern (P2); useCadenceReminders 30s tick iterates all cadences×meetings (P2, memoize nextEventAt); CalendarView buildEvents not useMemo'd (P3 ✗). **Hooks:** circular import (#5); prepQuestions memo deps may not memoize (P2); useCadences inner fetch no useCallback (P2). **Coherence:** CadenceHub:479 verbatim assignee\_email + :750 split("@") (Batch 2 claims [x] — VERIFY still fixed, else ownerLabel) (P1); handleSummarizeRequest globalPeople — verify normalizePerson applied to email-only (P1); two CalendarViews different visual grammar for same data — extract shared CadenceEventChip if confusing (P2); meetings account\_ids read inconsistently (some m.account\_id only) (P3). **Mobile:** verify previewModal portals to body not inside scroll container (iOS clip) (P1); CadenceMeetingMode AddContactInline — verify Batch 7 11px fix landed (P1 VERIFY); Notes|Projects toggle + End button overlap on 375px (P2); reminders need app open (PWA push deferred, doc) (P2). **A11y:** HistoryRow expand is div onClick — no role/tabIndex/onKeyDown, keyboard can't expand (P2); BeforeYouStart buttons — verify



not div (P2); calendar day cells no role=gridcell/grid (P3 ⚡ both CalendarViews). **Theme:** BeforeYouStart button colors — verify C.accent not hardcoded green (else stuck green in Life mode) (P2); HubProjectCard health pill + CalendarView pip-line colors verify tokens (P3). 🧠 **PIP-FEED (more):** verify **project notes (per-project blocks) actually reach summarize payload via onSummarize chain** — item 41 flagged unverified (P1); cadence brief callCadenceBriefPip missing waiting\_on tasks → "blocked on admin 12d" not in pre-call read (P2); operator state (operator\_situation/risks) not injected into summarize (P2, echoes D9); buildGlobalCadenceInsight string never fed to daily brief (P3 OPP). **Security:** verify folio\_contacts RLS is (select auth.uid())=user\_id (client .eq redundant — confirm not masking misconfig) (P1); meeting\_time malformed "25:99" overflows via setHours (P3 ⚡ validate). **Dead code:** document cadence/CalendarView scoping comment (P2); BeforeYouStart not exported (P2 note).

## D7 — Gauge

CONFIRMS the June-handoff dual-task-model worry: tasks split between gauge\_projects.stages (jsonb) and folio\_tasks — no surface shows both.

### Top 5 (highest impact):

1. [P0] StandingBoardView.jsx:48-56 commitTask never calls autoStatusPatch → **completing last kanban card doesn't flip project to complete** (heal effect only runs once on mount). Standing projects stay "In Progress" forever. 🔧 FIX
2. [P1] **DUAL TASK MODEL SPLIT-BRAIN** — pipPlanApply new\_task writes to project.stages; MyQueueView reads stages only; FlatTaskQueue + TeammateDetailView read folio\_tasks only → Pip-assigned tasks invisible in flat queue & teammate view; flat-queue tasks invisible in My Queue. No single complete view. Pick one canonical store or read both everywhere. 🔧 FIX/🔍
3. [P1] LeaderProjectsView.jsx:26-33 local STATUS\_LABELS map + C["status"+key] string-concat tokens → App Coherence violation on the BOSS-FACING view; new/renamed status → raw key or undefined (no styling, light-mode break). Use gaugeStatusLabel()/gaugeStatusToken(). 🔧 FIX
4. [P1] PipGaugeCard.jsx:215 onApprove/onDismiss .catch(()=>{}) silent → failed "Add task" = no feedback/log/retry (Guard 1 should catch — verify). logSilentFailure. 🔧 FIX; also TemplatePickerModal:51 + MyQueueView commitTask/deleteTask unhandled (P1-2).
5. [P1] **waiting\_on absent from LeaderProjectsView** — "who has the ball" exists everywhere else but not the one rollout a leader uses to triage blocked work. Also missing from PipGaugeCard sidebar + hidden on mobile GaugeView (desktop-only chip). ⚡/🔍

**Coherence:** LeaderProjectsView + TeammateDetailView count accounts via p.account\_id only, miss account\_ids[] (P2-3 ⚡, use projectMatchesAccount); FlatTaskQueue bespoke empty-state not shared EmptyState (P2) + uses email.split("@")[0] for initials (email leak, Batch 2 missed this file → resolveAssignee) (P2). **Race/concurrency:** commitTask full {stages:...} overwrite from in-memory snapshot → two-device clobber (P1); pipPlanApply projectStaging snapshots stale activeProjects → edits during preview-modal-open silently discarded on apply (P2, re-fetch before flush); RPC gauge\_patch\_stage would fix like gauge\_append\_status\_update. 🔍 🧠 **PIP-FEED:** TeammateDetailView per-stage assignees shown in UI but NOT sent to Pip → "what's on Dana's plate" unanswerable (P1, emit stage assignees in pipContext); PipGaugeCard narrative is pure JS heuristic, never reads operator\_situation/pip\_account\_state (P2); pip.js summarize emits only latest status\_update vs chat's latest+2 (P3 parity); gaugeFields formatFieldValue person-type resolves members only not contacts → raw email chip on cards (P2). **Correctness (more):** PipGaugeCard team-load keys on s.assignee|s.assignee\_email but panel only writes assignee\_email → s.assignee always undefined, inconsistent keying (P2). **Date:** PipGaugeCard:24 + TeammateDetailView:29 isOverdue new Date(d+"T00:00:00") device-tz dependent → add isOverdue() to dateUtils (P2 ⚡). **Mobile/a11y:** StandingBoardView column "+" button title not aria-label (P2 ⚡, Batch 7 missed); TaskDetailPanel autoFocus shifts modal on mobile (P3). **Perf:** PipGaugeCard not useMemo'd — recent-activity O(n×m) over all stages on every render incl. search keystroke (P2); TeammateDetailView theirProjects double-loop (P3). **Game:** GaugeView heal effect only fixes tasks w/ parent.stan.index — new Pip stages tasks lack it

(P3). **Sup3:** Stage view near effect only fixes tasks w/ parent\_step\_index — new Pip stages tasks lack it, never healed (P2, symptom of #2); ProjectNotesEditor savedAt null shows "Autosaves" even for existing notes (P3).

## D8 — Home / operator / check-in / commitments

CONFIRMED CLEAN: checkIn.js (data-line, pure/deterministic, daysBetween uses T00:00:00); StatusBanner suppressed when operatorActive; digest data-line at source; QUIET-no-person fix present.

### Top 5 (highest impact):

1. [P1] **item-38 owner suppression HALF-implemented** — HomeView:875 burningRows (Fires card) + :952 aheadRows (Growth warm) ignore owner\_user\_id → "not mine" MSO accounts reappear as fires/nudges in the MOST prominent surface (exactly what Chris killed). Also StatusBanner cold count (fallback path). Two one-line guards.  FIX
2. [P2] CommitmentsView.jsx:95 — onOpenAccount(acct) passes full OBJECT vs HomeView's onOpenAccount(account.id) → account-chip tap opens wrong account or crashes on .name. One-char fix.  FIX
3. [P2] HomeView:1719 "+N more" on "Your Word" card is inert text, onOpenCommitments in scope but unused → navigation dead-end from most-prominent card.  GAP
4. [P2] HomeView:975-980 heroLine uses unfiltered commitmentNudges.length not wordCommitments.length → orb says "3 promises due" while check-in already handling 2 → Pip looks unaware of his own check-in.  FIX
5. [P2] HomeView:304,257 brief cache key UTC vs snapshots ET → 8pm-midnight ET window caches stale snapshot data under "tomorrow" key → next morning's brief is stale. Use ET date.  FIX (also DigestIngestModal:83 same UTC issue P3 )

**Correctness:** HomeView:615 brief effect missing accounts in dep array → brief never rebuilds if accounts load after guard passes (P2). **Stale copy (operator cron retired):** useOperatorReport.js:14 "cron via service role" (P3 ) ; HomeView:273 "nightly loop" (P3 ) ; useFolioHealth.js:89 canary "Overnight operator run" / "No operator run in 3+ days" now actively misleading — fires on any day Chris doesn't tap Run = normal (P3 ) , relabel); OperatorHub:149 build-history comment (P3 ) .

**Operator/manual:** OperatorRunButton:21 no fetch timeout (hangs in "working" forever) + never reads JSON error body (P2); OperatorHub:239 draftFor matches account\_name string → casing/space mismatch silently kills "♦ Draft ready" → join by account\_id (P2); first-run prompt lacks "why" copy (P3); OperatorHub no full-date on "last run" → 2-dav-old report shows just "7:14 AM" looks like today (P2).

**Perf/hooks:** useAccountSnapshots.js:14 var fetch shadows global fetch (same footgun as item 36 fix) → rename (P2); useCommitmentNudges no realtime → nudge doesn't clear cross-device/after check-in (P3); HomeView:1301 playSequence hardcodes 6 cards → brittle (P2); checkInAnswered reads localStorage in hot memo every render → useState instead (P2). **Mobile (Guard 4 may be MISSING these!):** QuickActionBar.jsx:156 select fontSize:13 + :166 input fontSize:13 — sub-16px, global coarse rule saves runtime but SOURCE violation; Guard 4 should be failing CI on these → verify guard regex (P2, important — guard may have a hole). **Theme:** DigestIngestModal:161 color C.bg on accentDeep bg → near-invisible button text in light mode (P2 ) , use white/onAccent token).  **PIP-FEED:** burningRows (overdue items + blocked projects) computed for display but NOT in callPortfolioBriefPip payload → brief quiet about a 7d-overdue item screaming in Card 2 (P2); check-in answers don't refreshBrief() → brief says "All Star overdue" after Chris marked it done this morning (P3, call refreshBrief on mutating answer).

**A11y:** CheckInCard receipts lack role=status/aria-live (P3).  **ARCH (split candidates):** HomeView 2405 lines → extract HomeBriefHub.jsx (carousel+voice ~600 lines) → under 1800; extract burningRows/aheadRows → useHomeSignals.js (single place for owner\_user\_id fix + testable + reusable in operator roll-up).

## WAVE 2 ADDED PATTERNS

- **item-38 owner\_user\_id suppression is partial across the app** — operator-run + HomeView cold/anomaly have it; burningRows/aheadRows/StatusBanner/generate-questions/pip-state-refresh do NOT. Needs a single shared `isMine(account, userId)` helper applied everywhere (App Coherence).
- **Guard holes:** Guard 1 (silent catch) missed PipGaugeCard `.catch(()=>{})` + CadenceHub clipboard; Guard 4 (16px) missed QuickActionBar 13px + (maybe) CadenceTab/CadenceMeetingMode inline forms. → X5 must re-prove guard teeth + widen patterns.
- **Concurrent full-array overwrite** of jsonb (stages, project\_notes) is a cross-domain race class (D6,D7) → RPC patch pattern (like gauge\_append\_status\_update) is the systemic fix.
- **Split candidates confirmed:** CadenceHub 2416, HomeView 2405, SettingsView 1835 (D12 pending), pip.js 1580 — all over 1500.

## X4 — Live DB advisors (Supabase MCP, project "Pip" yrpdjmyfidhxlpmxasao) ✓

IMPORTANT CONTEXT: this ONE Postgres project hosts MULTIPLE apps (Folios + Lanyard [partners/sessions/user\_prefs] + a families/grocery/community app + DailyTrot is separate). Many lints belong to the OTHER apps — leave-alone per CLAUDE.md, but noted for awareness.

**Folios RLS held (item 47 verified live):** ZERO `auth_rls_initplan` lints on any folio\_/gauge\_/pip\_/life\_ table (all 23 belong to the families/community app). ZERO unindexed-FK lints on Folios (all 17 are the other app). The (select auth.uid()) wrap + FK indexes from Batch 0/3 are confirmed live. ✓

### SECURITY advisors (Folios-relevant):

- [P2] 4 functions with mutable search\_path (WARN): update updated\_at, update last interaction, folio\_tasks\_touch\_updated\_at, set\_updated\_at → add `SET search_path = ''`. 🔧
- [P2] 6 SECURITY DEFINER functions EXECUTABLE BY anon AND authenticated via REST RPC: folio\_member\_role\_unchanged, folio\_org\_peer\_user\_ids, folio\_user\_org\_ids, folio\_user\_writable\_org\_ids, gauge\_owner\_unchanged, **rls\_auto\_enable** (plpgsql — most concerning). These are RLS-helper internals, should NOT be public RPC. → REVOKE EXECUTE FROM anon, authenticated. 🔧
- [P2] auth\_leaked\_password\_protection DISABLED → enable HavelBeenPwned check (dashboard toggle). 🔧
- [note, NOT ours] always-true RLS on messages/notifications ("Anyone can read and write") + families/partners/sessions/user\_prefs — these are the OTHER apps in the shared DB; wide-open. Flag to Chris that a shared DB means another app's loose RLS sits beside Folios data (separate tables, but same project). Leave-alone per rule.

### PERFORMANCE advisors (Folios-relevant):

- [P2/P3] **multiple\_permissive\_policies** — 70 on Folios tables: folio\_accounts (20!),

folio\_org\_members (10), gauge\_projects (10), folio\_activity/operator\_reports/orgs/pip\_account\_state/pip\_facts/tasks (5 each). The org-layer "own + org" duplicate policies — INTENTIONAL per Phase 0 but each re-evaluates per row per command. Negligible at solo scale; consolidate into single OR-policies if multi-user. 

- [P3] **unused\_index** — **55 on Folios tables**, incl. DEAD-FEATURE indexes: folio\_items (unified → tasks), folio\_revenue\_history, folio\_shop\_metrics, folio\_email\_threads, folio\_thread\_events, folio\_audit\_log, pip\_correction\_log\_archive. Batch 3 already planned to drop 8 dead indexes — these confirm + extend the list. Drop dead-feature indexes to cut write overhead; leave low-volume-but-valid ones (planner will use at scale).  

**Verdict:** Folios DB security/RLS posture is SOUND (the scary classes are clean). Remaining = hardening (search\_path, revoke anon RPC, leaked-pw toggle) + housekeeping (policy consolidation, dead-index drop). No P0/P1 DB issues.

D14 — Standalone **gauge/** app  → **VERDICT: KILL** (delete entire /gauge/ dir)

Abandoned pre-V3 prototype. Evidence: NOT in root vercel.json/vite.config/package.json, no .vercel/ link, not in CI, no src/ imports it (apparent ../gauge/ imports resolve to src/views/gauge/), last meaningful update pre-June-10. Fully superseded by src/views/gauge/ (which is 4+ days ahead + has all V3 features). Zero users, zero deploy dependency.

**Why kill (not just ignore) — it carries live rule violations:**

- [P0] gauge/api/pip.js:74 — **new Anthropic()** OUTSIDE try-catch + no ANTHROPIC\_API\_KEY early guard (Vercel Serverless Rule violation → FUNCTION\_INVOCATION\_FAILED).
- [P0] gauge/api/pip.js:61-64 — Supabase client built WITHOUT JWT forwarding (Server-Client Auth Rule violation; latent if a .from() is ever added).
- [P0] gauge/index.html:7-9 — Google Fonts CDN (locked Font Rule violation).
- [P1] gauge/api/pip.js:27 — status schema diverged: uses active/cancelled/completed vs prod draft/planned/in\_progress/blocked/complete/on\_hold → silent data corruption if reached.
- [P1] gauge/src/hooks/useProjects.js:13 — SELECT has no explicit user\_id filter (RLS-only, fragile vs main app's belt-and-suspenders).
- [P2] 10+ duplicated components (Modal/TextField/UserMenu/PipMark/GaugeIcon...) — dark-only hardcoded colors, no token/theme, pure maintenance liability + divergence risk.
- [P2] no .gitignore in gauge/ → node\_modules would commit if npm install run there.

**ACTION** (auto-fixable as a clean deletion, but HIGH-impact → confirm with Chris first): **git rm -r gauge/**. Confirm **git log -- gauge/** has nothing worth preserving (only an incidental June-13 iOS-audio commit). No DB cleanup needed (live gauge\_projects owned by src/views/gauge/). → This is the single biggest security-surface reduction in the whole audit.  

D2 — Auth · org · session · activity 

VERIFIED CLEAN: 60min inactivity timeout correct; password strength (8+/upper/digit); getSession (not getUser) for full\_name patch; LeadershipView role-gating solid; folio\_activity solo-user SELECT policy present (Batch 2.9); activity.js guard-ok fire-and-forget correct; invite.js getUser inside try-catch + org-owner authz check; AuthView all C tokens + 16px InputFields.

#### Top 5 (highest impact):

1. [P1] api/invite.js:47 — **appUrl** from request body embedded in invite email link **unvalidated** → any member sends Folios-branded phishing link to evil.com. Allowlist origins.   
FIX/security
2. [P1] useAuth.js:12-23 — **folio\_portfolio\_brief\_<userId>** NOT in **SENSITIVE\_LOCALSTORAGE\_PREFIXES** → Pip's full portfolio analysis (account names/risks) survives signout, readable by next user on shared device. Also missing: folio\_pip\_state\_refresh\_last\_, folio\_pip\_compression\_last\_, folio\_checkin\_dismissed\_.   
FIX/security
3. [P1] schema.sql + team\_org\_layer.sql — **canonical schema has WEAK members\_self\_accept** (no email-guard / role-immutability); phase1\_security.sql hardening never folded in → fresh DB rebuild = role-escalation vector (accept any invite by UUID, escalate to owner). Fold phase1\_security.sql into schema.sql.  FIX
4. [P1] api/invite.js — **no rate limit** → authenticated user floods arbitrary emails via Resend at no cost (every other side-effect endpoint has one). Add per-user limiter.  GAP/security
5. [P2] useOrg.js:81-90 — pending-invite lookup queries invited\_email but **no RLS policy allows invited\_email SELECT** (members\_self\_read needs user\_id=auth.uid(), but pending invites have user\_id NULL) → **invite banner never renders for new users** (latent bug). Add members\_invite\_read policy.  FIX

**Security (more):** invite.js no email-format validation, raw email to Resend to: (P1, regex guard); LeadershipView folio\_tasks query no client-side org/user filter, RLS-only (P2 doc assumption); search\_history global key not user-scoped → cross-user overwrite (P2 ). **Correctness:** no TOKEN\_REFRESH\_FAILED handling → silent logout w/ no message (P2 UX); invite.js missing maxDuration config (P2, Resend call could hit 10s default). **Coherence/data:** logActivity no-ops when orgId null (solo user) AND activity\_insert RLS requires org → **audit-trail feature is a no-op for solo Chris** (P2, add solo insert policy or document). **A11y:** AuthView success message lacks role=status/aria-live (error has it) (P3). **Docs:** operator "nightly cron" stale in docs (P2, confirmed again). **Tests:** zero coverage on useAuth/useOrg/useActivity/activity.js/invite.js despite security weight — signout-wipe + invite-authz + sanitizePayload are prime unit-test targets (P2).

## D11 — Pip + Hex visual system

GOOD: frozen Pip geometry + drift lock HELD (no PIP\_SPEC violations, no inline Pip drawing, no numeric size enum misuse found). Visual system is disciplined — the one offender is HexRingCanvas.

#### Top 5 (highest impact):

1. [P2] HexRingCanvas.jsx:53,117-118,126 — **hardcoded teal #5bbfa0 / rgba(74,155,130) / rgba(159,240,210)** bypass accent tokens → won't re-skin in Life-mode orange or light theme (sole Hex surface that regressed). Read var(--c-accent) via getComputedStyle at draw time.  FIX
2. [P2] HexRingCanvas — **no prefers-reduced-motion guard** (only animated Pip/Hex surface that ignores it; WCAG 2.3.3). 3 lines.  FIX
3. [P2] HomeView.jsx:2010 — **<HexSignature cells={2} peak={0.10}>** — **cells=2 is NOT a valid Hex Grammar encoding** (spec = 3 user / 5 Pip). Off-spec drift entry point.



→ cells={3} peak={0.13}.  FIX

4. [P2] HexRingCanvas — all 6 HomeView instances run live rAF regardless of `active` (active = CSS opacity only) → 5/6 draw invisible frames always; gate rAF on active → ~83% fewer draw calls at rest. 
5. [P3] AuthView.jsx:310 — `<HexSignature cells={3} peak={0.28} cell={5}>` — peak 0.28 (between canonical 0.13/0.30) + cell override → third off-spec entry. Snap to canonical. 

**More:** PipOrb3D.jsx:5 stale comment "2.4s cycle" (now 4.8s) (P3 ); HexLattice missing the `if(op<=0.004) continue` skip that HexField has (~520 paths, perf parity) (P3); verify AccountsView:523 Quick Tasks tray HexSignature is panel-level not per-row (P3, Hex Grammar "rows never"). **VERDICT:** Pip visual discipline is strong; HexRingCanvas is the lone straggler that predates/sidesteps the token+reduced-motion conventions. Quick cluster fix.

## D12 — Shared components & design system

Token system HEALTHY (all 83 C.\* keys map to var(--c-\*), all defined in dark+light; Life inherits base by design); PipGlyph whitelist tight (no XSS).

### Top 5 (highest impact):

1. [P0] Pill.jsx:5 — `var(--c-text-mute)` typo (token is `--c-text-muted`) → EVERY `<Pill>` without explicit color renders INVISIBLE text app-wide (status/category/gauge chips). One-char fix.  FIX  (but high-impact, verify)
2. [P1] Modal.jsx — `no role="dialog"/aria-modal/aria-labelledby` + `no body scroll-lock` + `not portaled`. Most-used overlay (14+ callers) → inaccessible to screen readers + background scrolls on mobile.  FIX
3. [P1] AccountPicker.jsx:156,232 — inline `outline:"none"` suppresses global `:focus-visible` → **most-used picker has zero keyboard focus indicator**. Remove overrides.  FIX/a11y
4. [P1] Toast.jsx — error toasts use `role="status"` `aria-live="polite"` not `role="alert"/assertive` → **failures may never be announced** to screen readers. Two-container fix.  FIX/a11y
5. [P1] SettingsView.jsx 1835 lines, 10 named section components → top split candidate (extract to sections/, enables lazy-load; SETTINGS\_MONO var-hoisting fragility).  FIX

**Theme (token bypasses, light/Life breakage):** ErrorBoundary:170,210 `color:"#fff"` (P1); UserMenu:128 hardcoded `#091712` (P1); index.html `--c-bg-pill-active` not defined in Life blocks → ModeToggle active segment wrong in Life (P1); home-card-ring-glow keyframe hardcoded teal rgba → stays teal in Life-orange (P2); CommandPalette/Tooltip/ConnectionStatus raw rgba shadows → overlay-shadow tokens (P2 ); Life blocks don't redefine `--c-glass/--c-pip-card-` → green glass on blue bg (P3). **A11y batch (P2 mostly):** ChipDropdown no `aria-haspopup/listbox/option` + no arrow-key nav; UserMenu dropdown no `role=menu/menuitem` + no arrow-key; InfoTip/Tooltip no `role=tooltip` + `aria-describedby`; ErrorBanner has BOTH `role=alert` AND `aria-live=polite` (polite wins → not assertive); AccountPicker clear-x is span not button + no `aria-activedescendant`; MarkdownText `##` renders as div not h2/h3 (flat outline); CommandPalette no scroll-into-view on keyboard nav; Glow renders

for decorative text; AddToTasksButton/Gaugelcon missing aria. **Correctness:** MarkdownText:61 normalizeStructure dash → list regex could match "20 - 30"/"4:00 - 5:00" prose (P2 latent, tighten). **Coherence:** Buttons.jsx 4 button variants w/ inconsistent prop interfaces (DangerBtn can't take type/aria-label) (P2); LitPill sets disabled not aria-disabled (P2); SettingsView raw ☐ — re-verify whether Guard 4 actually flags them or if they're multi-line JSX (Guard 4 fragility). Net: guards need (1) Guard 1 missing-catch detection + dotAll + comment-only=empty, (2) Guard 4 multi-line JSX robustness.

## ALL 14 DOMAINS COMPLETE.

### X1 — Pip context parity sweep ☒

#### THE PARITY MATRIX (which surface sees which field):

| Field                                                                                                                                                                                                                                                                                                       | chat<br>(pipContext)                           | Brief<br>Me                         | summarize<br>(pip.js)                            | operator                            |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------|-------------------------------------|--------------------------------------------------|-------------------------------------|
| globalPeople (roster)                                                                                                                                                                                                                                                                                       | ✗ NOT WIRED                                    | ✗                                   | <input checked="" type="checkbox"/>              | <input checked="" type="checkbox"/> |
| healthSnapshots                                                                                                                                                                                                                                                                                             | ✗ (renderer reads it, caller doesn't populate) | <input checked="" type="checkbox"/> | <input checked="" type="checkbox"/><br>(cadence) | <input checked="" type="checkbox"/> |
| promiseStats                                                                                                                                                                                                                                                                                                | ✗                                              | partial                             | <input checked="" type="checkbox"/>              | n/a                                 |
| project waiting_on/assignee                                                                                                                                                                                                                                                                                 | ✗                                              | ✗                                   | <input checked="" type="checkbox"/>              | <input checked="" type="checkbox"/> |
| operator_situation/risks                                                                                                                                                                                                                                                                                    | <input checked="" type="checkbox"/> (chat)     | n/a                                 | ✗ NOT WIRED                                      | source                              |
| recentUpdates                                                                                                                                                                                                                                                                                               | <input checked="" type="checkbox"/>            | ✗                                   | <input checked="" type="checkbox"/>              | <input checked="" type="checkbox"/> |
| status_updates pulses                                                                                                                                                                                                                                                                                       | latest+2                                       | latest only                         | latest only                                      | —                                   |
| <b>Verdict:</b> parity rule is a manual discipline that HAS drifted.<br>chat<BriefMe<summarize context tiers.<br>Root cause = 3 independent renderers (X6 F1 fixes structurally). Highest-impact single fix: wire globalPeople+health+promise into PipView.buildContext (the renderer already supports it). |                                                |                                     |                                                  |                                     |

## X2 — Data-line compliance sweep

STRONG overall. PASS: all generative endpoints (profile-synthesis, generate-questions, detect-terminology, followup-question, operator ACCOUNT/REPORT systems) carry explicit data-line instructions; checkIn.js, AddLifeItemModal, digest WORK\_CLAUDE PROMPT all clean at source; summarize inherits via PIP\_PERSONA. **Two real gaps:** (1) D9 — `remember_fact` tool description doesn't forbid quantitative data → Pip could store a number from chat (P2); (2) D9 — `compressCorrectionsPip` prompt lacks generalization instruction → a correction mentioning "\$2M" could embed in `lessons_learned` (P2). Both one-line prompt additions.

## X3 — Coherence sweep (Frankenstein quantified)

Recurring duplication/drift classes across domains:

- **STATUS\_LABELS / health-vocab duplicated:** `AccountDetailHeader`, `AccountsView`, `OverviewTab` ("Watch" vs "Watching"), `LeaderProjectsView` — multiple local maps; green/yellow/red (runtime) vs healthy/watching/at\_risk (snapshot) for same concept. → export from `accountHealth.js` + `gaugeStatus.js`.
- **UTC-vs-ET date parsing** recurs ≥6 sites (`accountHealth:98`, `AccountDetail:228`, `pip.js` `commitments`, `_pipUsage:122`, `HomeView` brief key. `DiagEstInaestModal:83`) despite `dateUtils` — Guard 2 only catches `toLocaleDateString` not `new Date("YYYY-MM-DD")`.
- **Hardcoded rgba light-mode breakage:** `D3(4)`, `D4(4)`, `D11(HexRingCanvas)`, `D12(ErrorBoundary/UserMenu/keyframe)` — systemic; ~15+ sites.
- **Shared component non-adoption:** `EmptyState` (`D4×4`, `D7`), `SelectField` (`D12×3`), `PersonPicker` `fontSize`, `InfoCard`.
- **owner\_user\_id isMine() suppression partial:** `operator+HomeView` cold/anomaly have it; `burningRows/aheadRows/StatusBanner/generate-questions/pip-state-refresh` don't → need ONE shared helper.
- **email-leak recurrence:** `ItemsTab:255`, `FlatTaskQueue`, `CadenceHub:479/750` — `ownerLabel/resolveAssignee` not applied everywhere.
- **Dual implementations:** two `CalendarView` (intentional, undocumented), dual task model (`stages` vs `folio_tasks` — real split-brain), three Pip context renderers (X6).

## X5 — Guard / CI integrity (precise verdict from D13)

- **Guard 1 (silent catch):** catches EMPTY bodies in `src/+api/` (verified). BLIND to: (a) MISSING `.catch` entirely (`CadenceHub` clipboard), (b) multi-line empty bodies, (c) comment-only bodies `/* ignore */` read as non-empty (`PipGaugeCard` escaped via this). → add missing-catch detection for high-risk `async` + `dotAll` + treat comment-only as empty.
- **Guard 4 (16px):** works on current code but fragile on multi-line JSX where `fontSize` follows the first `>`. `QuickActionBar` 13px — re-verify it's actually caught.
- **Guard 2/3:** sound (Guard 3 correctly `api`-scoped).
- **Classroom:** `npm run lint` step: `npm audit` step: Add both (`audit` `omit-dev`)



- **Organs:** no npm run lint step, no npm audit step. Add both (audit --omit=dev).
- **New guards to add:** Guard 5 hook-order (App.jsx use\* below authLoading — React #310, bit Chris 3x); Guard 6 `new Date("YYYY-MM-DD")` without T00:00:00 (the ET drift class).

## X6 — Pip Architecture Review (Opus capstone)

**HOW PIP IS WIRED:** 13 endpoints over 1 Postgres; context assembled per-surface client-side, no shared service. Same "account context" rendered by THREE independent functions (pipContext.renderAccountFull / pip.js summarize blocks / operator-run.renderAccountContext) → guaranteed drift. One genuinely materialized layer (folio\_pip\_account\_state); memory = flat prose (no semantic recall). pipTools defines 13 tools but it's SINGLE-TURN (no tool\_result round-trip) — Pip is a one-shot function-emitter, not an agent.

**WHERE IT HOLDS PIP BACK:** (1) tri-path context model → "built but not wired" is a SYMPTOM, parity rule can't hold; (2) no single materialized context layer; (3) JSON-mode not a real agent loop; (4) flat memory, no recall (undercuts "portable brain" promise); (5) timer-driven not event-driven recompute (pip-state-refresh burst); (6) BP2 profileProse cache fragility.

### THE BETTER SHAPE:

-  **FEED** (ranked): 1. wire chat to globalPeople/health/promise (renderer exists — kills #1 complaint, near-zero effort); 2. operator state → summarize; 3. pre-meeting check-in answers → summarize; 4. waiting\_on → cadence brief+leader; 5. digest as live feed.
-  **FORM** (sequence): **F4** cache fixes (cheap money) → **F1 single buildAccountContext() layer (KEystone)** → F3 event-driven recompute (70-90% cost cut) → F2 persist structured context into state row → F5 real agent loop (tool\_result round-trip, chat only) → F6 pgvector semantic recall (Pip summaries only, raw notes stay verbatim per Data Line).
-  **NEW PARADIGMS:** digest as reasoning-ingest (closes capture gap by making the paste worth it), admin instruction-writer, event-driven proactive Pip, true conversational memory.

**THE ONE THING:** Build F1 — collapse the three context renderers into one `buildAccountContext()` and route chat/brief/summarize/operator through it. Fixes #1 complaint, makes the next 20 parity bugs impossible by construction, and is the foundation every ambitious capability stands on. <1 week, ships with tests. Do F4 cache fixes alongside for free money.